Controlled Phishing Awareness Simulation

GRC103 Practical Laboratory | Final Risk Assessment and Executive Brief

Student	Registration number	Simulation date
Adediran Eunice Adebukola	C11-26-CGRCE-17595	8 November 2026

1. Executive summary

A controlled phishing-awareness exercise was conducted in a Kali Linux lab using Gophish, five fictional recipient records and a local SMTP capture service. The campaign used an HR benefits review theme and a locally hosted training landing page. The purpose was to verify campaign configuration, event recording and the ability to translate observed events into governance reporting—not to measure actual employee susceptibility.

Gophish recorded five "Email Sent" events, one open, one link click and one simulated form submission; no reports were recorded. Each interaction represents 20% of the five fictional recipient records. The submission involved a fictional lab reference, not a password. These figures establish successful event-tracking in the lab but do not demonstrate real-world delivery or control failure.

2. Results and calculated rates

Metric	Recorded events	Rate / denominator	Assessment
Emails sent	5	5/5 = 100%	Local SMTP processing confirmed; external delivery not tested
Emails opened	1	1/5 = 20%	Open event successfully recorded
Links clicked	1	1/5 = 20%	Tracked URL visit successfully recorded
Form submissions	1	1/5 = 20%	Fictional lab reference submitted and recorded
Emails reported	0	0/5 = 0%	Reporting behaviour was not meaningfully tested

3. Phishing risk assessment (Step 8)

Metric	Observed rate	Risk interpretation	Control assessment
Open event	20%	Opening an untrusted message can create an opportunity for social engineering.	Awareness training effectiveness cannot be established from fictional recipients.
Link click	20%	Following an unverified link could expose a user to a spoofed service or credential request.	Email filtering and user verification controls were not tested in production.
Form submission	20%	Submission to a deceptive form could cause disclosure if real sensitive information were requested.	A fictional reference was used; no real credentials were submitted and MFA effectiveness was not tested.
Report event	0%	Prompt reporting supports detection and response, but no human reporting test occurred.	No conclusion can be drawn about the organisation's reporting culture.

4. Risk analysis and management implications

The exercise confirms that a themed message, personalised link and simulated landing page can be configured and monitored within a controlled environment. In an operational setting, similar social-engineering attempts may lead to account compromise, unauthorised access or data exposure when preventive and detective controls are weak. Those outcomes were not observed in this lab.

The sample is not representative: all five identities were fictional, messages were processed locally, and the engagement was generated during a deliberate test. Accordingly, 20% is an observed lab event rate—not a validated employee click-through rate, credential compromise rate or enterprise risk estimate.

5. Recommendations (Step 9)

Priority	Recommendation	Suggested owner	Verification / success criterion
High	Use phishing-resistant MFA for sensitive accounts and critical applications; review access to high-risk services.	Identity & Access Management	MFA policy and coverage evidence; exception register; test results
High	Provide practical awareness training on suspicious HR-themed requests, sender verification and safe link handling.	Security Awareness / HR	Training completion, knowledge checks and follow-up simulation results
Medium	Make “Report Phishing” mechanisms easy to use and establish triage, escalation and response expectations.	Security Operations	Reporting channel test; incident ticket and response SLA evidence
Medium	Validate email authentication and filtering (SPF, DKIM, DMARC, anti-phishing controls) in an authorised environment.	Messaging / Security Engineering	Configuration review, test messages and alert logs
Medium	Run periodic, formally authorised simulations using approved test recipients, predefined metrics and privacy safeguards.	GRC / Security Awareness	Approved scope, documented consent/authorisation, repeatable measurement and lessons learned

6. Methodology, scope and limitations

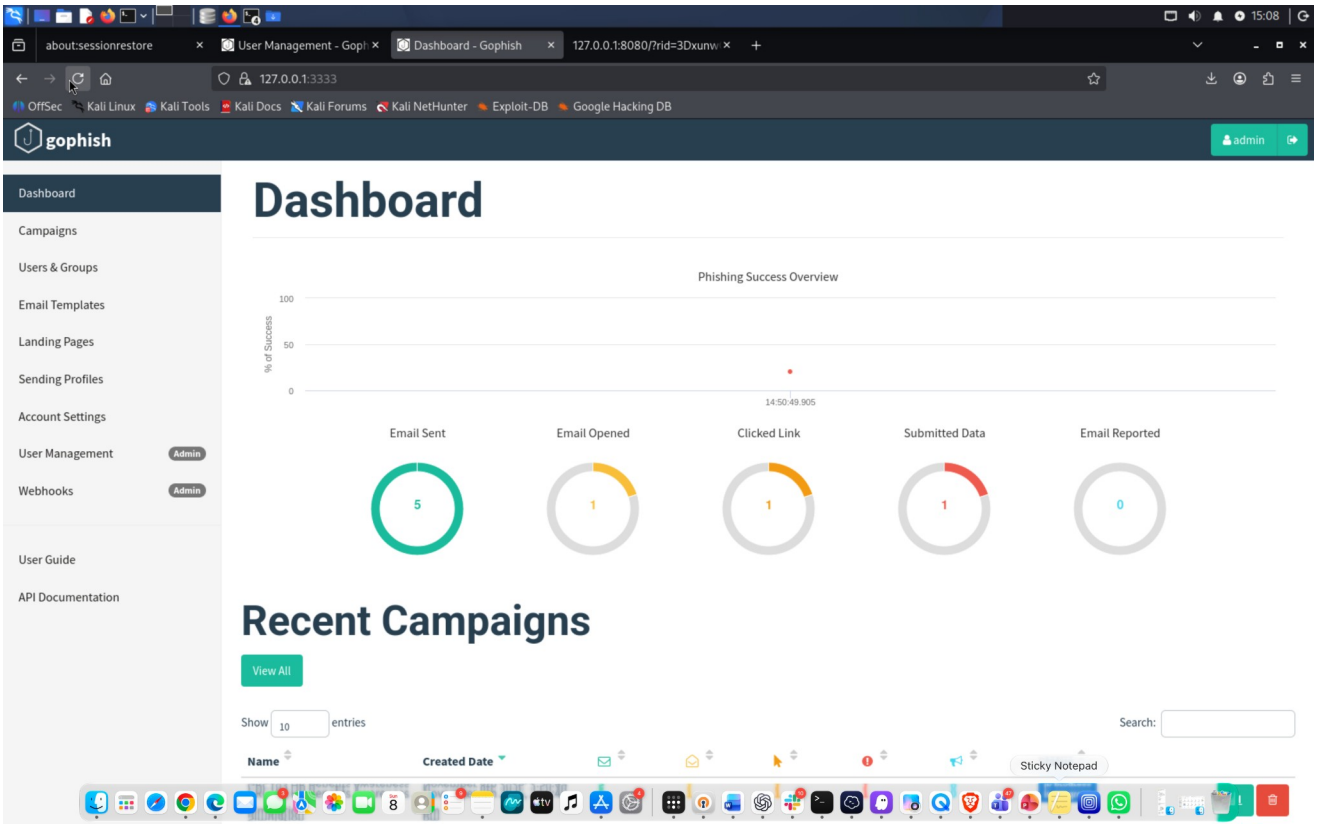
- Environment: Kali Linux virtual machine; Gophish admin interface on 127.0.0.1:3333 and phishing listener on 127.0.0.1:8080.
- Email infrastructure: Local SMTP capture listener; no evidence of external mailbox delivery or real employee targeting.
- Recipients: Five fictional lab identities. One scripted/manual interaction path was exercised to verify open, click and form-submission telemetry.
- Data handling: Only a fictional reference value was used in the landing page. No real password or personal information was requested.
- Evidence: Gophish results dashboard screenshot captured on 8 November 2026. The updated Gophish CSV is retained separately by the student in the Kali lab environment.

7. Conclusion

The practical successfully demonstrated a locally contained phishing campaign and the collection of measurable campaign events. Its governance value lies in translating technical telemetry into a defensible risk assessment while distinguishing a simulated workflow from real employee behaviour. A production awareness assessment would require a larger authorised population, validated delivery, clear baselines and retesting after controls are improved.

Appendix A — Original Gophish results evidence

Figure A1. Gophish dashboard captured in the Kali lab on 8 November 2026. Visible counters: five emails sent, one opened, one clicked, one data submission and zero reported. This is an authentic screenshot of the completed exercise; no dashboard metrics have been reconstructed.



Evidence interpretation: “Submitted Data” denotes a fictional lab reference submitted to a training page. The local SMTP capture setup prevents this evidence from being interpreted as proof of external email delivery.

Lab brief alignment: Deliverable 1 — Gophish dashboard screenshot; Deliverable 2 — phishing risk assessment table (Section 3); Deliverable 3 — executive summary and recommendations (Sections 1 and 5).

Preparation note: AI assistance was used to organise and edit the written report. All metrics and the screenshot are derived from the student-operated lab exercise.